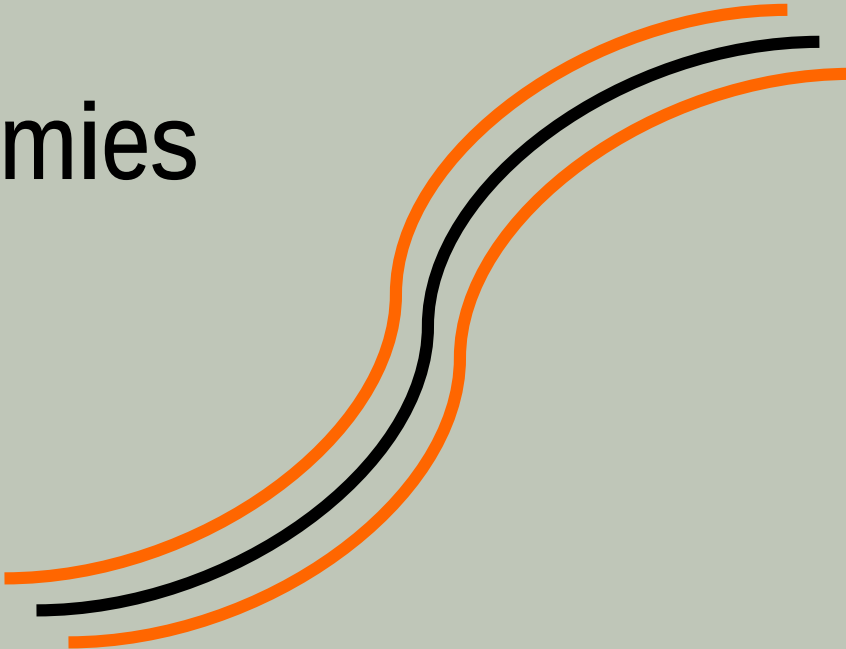




CEG 4424/6424

Security Attacks & Defenses

Vulnerability Taxonomies

Today's Objective(s)

Understand the most significant vulnerability taxonomies and how they are related.

- Common Vulnerabilities and Exposures (CVE)
- Common Weakness Enumeration (CWE)
- Common Attack Pattern Enumeration and Classification (CAPEC)
- Common Platform Enumeration (CPE)
- Common Vulnerability Scoring System (CVSS)
- U.S. National Vulnerability Database (NVD)
- Open Web Application Security Project (OWASP)

Recognize this understanding as a foundation for gathering detailed information about top cybersecurity errors, issues & vulnerabilities.

Disclaimer:

- Slide contents are from numerous sources:
 - Common Vulnerabilities and Exposures (CVE), <https://cve.mitre.org/about/>
 - Common Weakness Enumeration (CWE) - *A Community-Developed Dictionary of Software Weakness Types* <http://cwe.mitre.org/top25/index.html>
 - Common Attack Pattern Enumeration and Classification (CAPEC), <https://capec.mitre.org/data/index.html>
 - Common Platform Enumeration (CPE), <https://nvd.nist.gov/products/cpe>
 - Common Vulnerability Scoring System (CVSS), <https://www.first.org/cvss/>
 - National Vulnerability Database (NVD), <https://nvd.nist.gov/>
 - Open Web Application Security Project (OWASP) – Top Ten Project - https://www.owasp.org/index.php/Category:OWASP_Top_Ten_Project

Common Vulnerabilities and Exposures (CVE)

- Launched in 1999 when most information security tools used their own databases with their own names for security vulnerabilities
- At that time, no significant variation among products & no easy way to determine when the different databases were referring to the same problem
- Caused potential gaps in security coverage and no effective interoperability among the disparate databases and tools
- Each tool vendor used different metrics to state the number of vulnerabilities or exposures they detected
 - There was no standardized basis for evaluation among the tools.
- CVE's common, standardized identifiers provided the solution to these problems.
- CVE is now the industry standard for vulnerability and exposure names.
- CVE is a dictionary that provides definitions for **publicly disclosed** cybersecurity vulnerabilities and exposures

CVE cont'd

- CVE is:
 - One name for one vulnerability or exposure
 - One standardized description for each vulnerability or exposure
 - A dictionary rather than a database
 - Provides way for disparate databases and tools to "speak" the same language
 - Provides the way to interoperability and better security coverage
 - A basis for evaluation among tools and databases
 - Free for public download and use
 - Industry-endorsed via the CVE Numbering Authorities, CVE Board, and CVE-Compatible Products
 - Sponsored by U.S. Department of Homeland Security (DHS) Cybersecurity and Infrastructure Security Agency (CISA)
 - Operating as DHS's FFRDC, MITRE has copyrighted the CVE List
 - in order to ensure it remains a free and open standard
 - to legally protect the ongoing use of it and any resulting content by government, vendors, and/or users
 - MITRE has trademarked ® the CVE acronym and the CVE logo to protect their sole and ongoing use by the CVE effort within the cybersecurity arena

Common Weakness Enumeration (CWE)

- Common Weakness Enumeration (CWE) - *A Community-Developed Dictionary of Software Weakness Types*
 - Joint project between Mitre & SANS
 - <https://cwe.mitre.org>
- Targeted to developers and security practitioners, the Common Weakness Enumeration (CWE) is a formal list of software weakness types created to:
 - Serve as a common language for describing software security weaknesses in architecture, design, or code.
 - Serve as a standard measuring stick for software security tools targeting these weaknesses.
 - Provide a common baseline standard for weakness identification, mitigation, and prevention efforts.
- <http://cwe.mitre.org/top25/index.html>
- Top 25 Software Errors Grouped into 3 Categories
 - Insecure Interaction Between Components – 6 errors
 - Risky Resource Management – 8 errors
 - Porous Defenses – 11 errors

Insecure Interaction Between Components

These weaknesses are related to insecure ways in which data is sent and received between separate components, modules, programs, processes, threads, or systems.

CWE ID	Name
CWE-89	Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
CWE-78	Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')
CWE-79	Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')
CWE-434	Unrestricted Upload of File with Dangerous Type
CWE-352	Cross-Site Request Forgery (CSRF)
CWE-601	URL Redirection to Untrusted Site ('Open Redirect')

Risky Resource Management

The weaknesses in this category are related to ways in which software does not properly manage the creation, usage, transfer, or destruction of important system resources.

CWE ID	Name
CWE-120	Buffer Copy without Checking Size of Input ('Classic Buffer Overflow')
CWE-22	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')
CWE-494	Download of Code Without Integrity Check
CWE-829	Inclusion of Functionality from Untrusted Control Sphere
CWE-676	Use of Potentially Dangerous Function
CWE-131	Incorrect Calculation of Buffer Size
CWE-134	Uncontrolled Format String
CWE-190	Integer Overflow or Wraparound

Porous Defenses

The weaknesses in this category are related to defensive techniques that are often misused, abused, or just plain ignored.

CWE ID	Name
CWE-306	Missing Authentication for Critical Function
CWE-862	Missing Authorization
CWE-798	Use of Hard-coded Credentials
CWE-311	Missing Encryption of Sensitive Data
CWE-807	Reliance on Untrusted Inputs in a Security Decision
CWE-250	Execution with Unnecessary Privileges
CWE-863	Incorrect Authorization
CWE-732	Incorrect Permission Assignment for Critical Resource
CWE-327	Use of a Broken or Risky Cryptographic Algorithm
CWE-307	Improper Restriction of Excessive Authentication Attempts
CWE-759	Use of a One-Way Hash without a Salt

CAPEC

- Understanding how the adversary operates is essential to effective cyber security.
- The Common Attack Pattern Enumeration and Classification (CAPEC™) effort provides a publicly available catalog of attack patterns along with a comprehensive schema and classification taxonomy. <https://capec.mitre.org>
- It can be used by analysts, developers, testers, and educators to advance community understanding and enhance defenses.
- Can view the list of attack patterns two different ways
 - by Mechanisms of Attack - organizes attack patterns hierarchically based on mechanisms that are frequently employed when exploiting a vulnerability.
 - The categories that are members of this view represent the different techniques used to attack a system.
 - They do not, however, represent the consequences or goals of the attacks.
 - by Domains of Attack - organizes attack patterns hierarchically based on the attack domain
 - E.g. S/W, H/W, Comm, Supply Chain, Social Eng, Physical Sec

CAPEC

- Related activities

- Department of Homeland Security National Cyber Security Division's "Build Security In" (BSI) Web site, <http://buildsecurityin.us-cert.gov>
- Making Security Measurable collection of security standardization organizations, activities, and initiatives, <http://measurablesecurity.mitre.org>
- Common Weakness Enumeration (CWE) List of standardized software weaknesses, <http://cwe.mitre.org>
- Common Vulnerabilities and Exposures (CVE) List of standardized vulnerability names, <http://cve.mitre.org/cve>
- The Software Assurance Metrics and Tool Evaluation (SAMATE) project, National Institute of Science and Technology (NIST), <http://samate.nist.gov>
- Object Management Group (OMG) Software Assurance (SwA) Special Interest Group (SIG), <http://swa.omg.org>

CPE

Official Common Platform Enumeration (CPE) Dictionary

- CPE is a structured naming scheme for information technology systems, software, and packages.
- Based upon the generic syntax for Uniform Resource Identifiers (URI), CPE includes a formal name format, a method for checking names against a system, and a description format for binding text and tests to a name.
- The dictionary provides an agreed upon list of official CPE names.
- The dictionary is provided in XML format and is available to the general public.
- NOTE: the CPE Product Dictionary will continue to grow to include all past, present and future product releases and is updated nightly when modifications or new names are added.
- The CPE Dictionary hosted and maintained at NIST may be used by nongovernmental organizations on a voluntary basis and is not subject to copyright in the United States. Attribution would, however, be appreciated by NIST.

CVSS

- The Common Vulnerability Scoring System (CVSS) provides a way to capture the principal characteristics of a vulnerability and produce a numerical score reflecting its severity
- The numerical score can then be translated into a qualitative representation (such as low, medium, high, and critical) to help organizations properly assess and prioritize their vulnerability management processes.
- CVSS is composed of **three metric groups**, Base, Temporal, and Environmental, each consisting of a set of metrics, as shown in Figure 1.
- The Base metric group represents the intrinsic characteristics of a vulnerability that are constant over time and across user environments.
 - The Exploitability metrics reflect the ease and technical means by which the vulnerability can be exploited.
 - The Impact metrics reflect the direct consequence of a successful exploit, and represent the consequence to the *thing that suffers the impact*
- The Temporal metric group reflects the characteristics of a vulnerability that may change over time but not across user environments.
- The Environmental metric group represents the characteristics of a vulnerability that are relevant and unique to a particular user's environment.

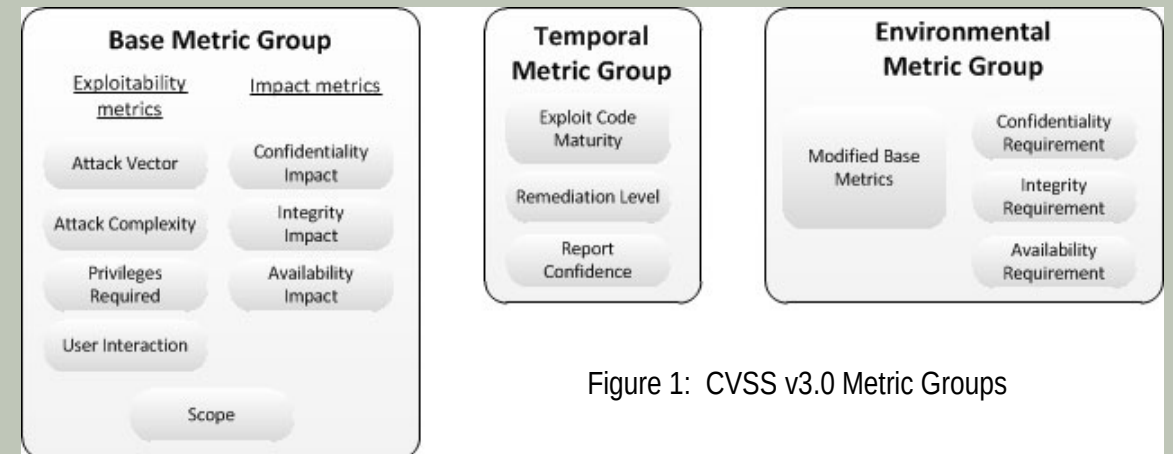


Figure 1: CVSS v3.0 Metric Groups

CVSS

- When the Base metrics are assigned values by an analyst, the Base equation **computes a score** ranging from 0.0 to 10.0 as illustrated in Figure 2.
- The Base equation is derived from two sub equations: the Exploitability sub score equation, and the Impact sub score equation.
- The Exploitability sub score equation is derived from the Base Exploitability metrics
- The Impact sub score equation is derived from the Base Impact metrics.
- The Base score can then be refined by scoring the Temporal and Environmental metrics.
- However, scoring the Temporal and Environmental metrics is not required.
- Generally, the Base and Temporal metrics are specified by vulnerability bulletin analysts, security product vendors, or application vendors because they typically possess the most accurate information about the characteristics of a vulnerability.
- The Environmental metrics are specified by end-user organizations
- Scoring CVSS metrics also produces a vector string, a specifically formatted text string that contains each value assigned to each metric, and should always be displayed with the vulnerability score.
- Note that all metrics should be scored under the assumption that the attacker has already located and identified the vulnerability. That is, the analyst need not consider the means by which the vulnerability was identified.
- Goto CVSS Calculator (<https://www.first.org/cvss/calculator/3.1>)

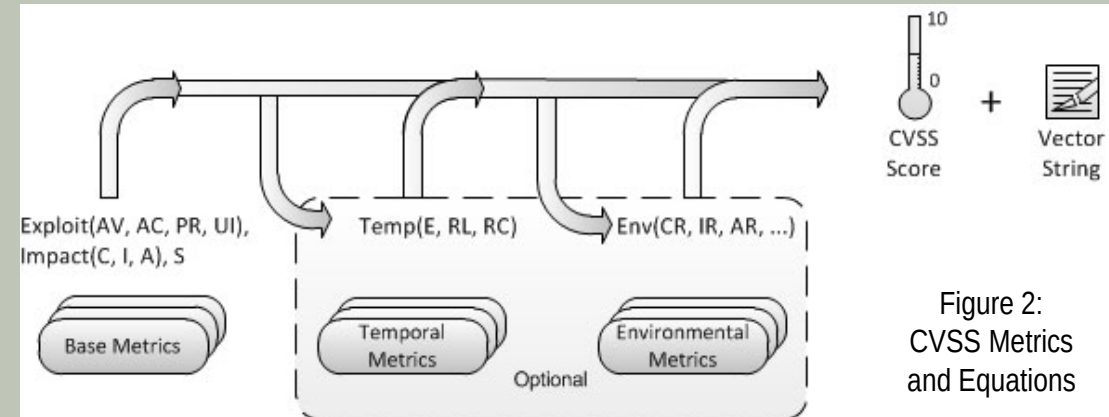


Figure 2:
CVSS Metrics
and Equations

CVE Details

CVE Details

- not part of the Mitre suite of tools
- Intended to provide easy to use web interface to CVE data

<https://www.cvedetails.com>

Vulnerability Details : [CVE-2015-0097](#)

Microsoft Excel 2007 SP3, PowerPoint 2007 SP3, Word 2007 SP3, Excel 2010 SP2, PowerPoint 2010 SP2, and Word 2010 SP2 allow remote attackers to execute arbitrary code via a crafted Office document, aka "Microsoft Word Local Zone Remote Code Execution Vulnerability."

Publish Date : 2015-03-11 Last Update Date : 2015-09-11

[Collapse All](#) [Expand All](#) [Select](#) [Select&Copy](#) [▼ Scroll To](#) [▼ Comments](#) [▼ External Links](#)
[Search Twitter](#) [Search YouTube](#) [Search Google](#)

– CVSS Scores & Vulnerability Types

CVSS Score	9.3
Confidentiality Impact	Complete (There is total information disclosure, resulting in all system files being revealed.)
Integrity Impact	Complete (There is a total compromise of system integrity. There is a complete loss of system protection, resulting in the entire system being compromised.)
Availability Impact	Complete (There is a total shutdown of the affected resource. The attacker can render the resource completely unavailable.)
Access Complexity	Medium (The access conditions are somewhat specialized. Some preconditions must be satisfied to exploit)
Authentication	Not required (Authentication is not required to exploit the vulnerability.)
Gained Access	None
Vulnerability Type(s)	Remote Code Execution
CWE ID	19

– Related OVAL Definitions

Title	Definition Id	Class	Family
Microsoft word local zone remote code execution vulnerability – CVE-2015-0097 (MS15-022)	oval:org.mitre.oval:def:28851		windows

OVAL (Open Vulnerability and Assessment Language) definitions define exactly what should be done to verify a vulnerability or a missing patch. Check out the OVAL definitions if you want to learn what you should do to verify a vulnerability.

– Products Affected By CVE-2015-0097

#	Product Type	Vendor	Product	Version	Update	Edition	Language	
1	Application	Microsoft	Excel	2007	SP3			Version Details Vulnerabilities
2	Application	Microsoft	Excel	2010	SP2	~~~x86~~		Version Details Vulnerabilities
3	Application	Microsoft	Excel	2010	SP2	~~~~x86~		Version Details Vulnerabilities
4	Application	Microsoft	Powerpoint	2007	SP3			Version Details Vulnerabilities
5	Application	Microsoft	Powerpoint	2010	SP2			Version Details Vulnerabilities
6	Application	Microsoft	Word	2007	SP3			Version Details Vulnerabilities

National Vulnerability Database (NVD)

- NVD is a product of the NIST Computer Security Division and is sponsored by the Department of Homeland Security's National Cyber Security Division
- Supports the U.S. government multi-agency (OSD, DHS, NSA, DISA, and NIST) Information Security Automation Program
- It is the U.S. government content repository for the Security Content Automation Protocol ([SCAP](#))
- NVD is the U.S. government repository of standards based vulnerability management data
 - This data enables automation of vulnerability management, security measurement, and compliance (e.g. FISMA)
 - Federal Information Security Modernization Act (FISMA)
 - FISMA 2014 updates the Federal Government's cybersecurity practices by:
 - Codifying Department of Homeland Security (DHS) authority to administer the implementation of information security policies for non-national security federal Executive Branch systems, including providing technical assistance and deploying technologies to such systems;
 - Amending and clarifying the Office of Management and Budget's (OMB) oversight authority over federal agency information security practices; and by
 - Requiring OMB to amend or revise OMB A-130 to "eliminate inefficient and wasteful reporting."
- Goto NVD Dashboard (<https://nvd.nist.gov/general/nvd-dashboard>)

Open Web Application Security Project (OWASP)

- Every vibrant technology marketplace needs an unbiased source of information on best practices as well as an active body advocating open standards
- In the Application Security space, one of those groups is the Open Web Application Security Project (or OWASP for short)
- OWASP is a 501(c)(3) worldwide not-for-profit charitable organization focused on improving the security of software
- Mission = make software security visible, so that individuals and organizations are able to make informed decisions
- OWASP is in a unique position to provide impartial, practical information about AppSec to individuals, corporations, universities, government agencies and other organizations worldwide
- Operating as a community of like-minded professionals, OWASP issues software tools and knowledge-based documentation on application security

https://www.owasp.org/index.php/Main_Page

OWASP Top 10 Most Critical Errors - 2013

[A1 Injection](#)

Parentetical notes = compared to
2010 list

[A2 Broken Authentication and Session Management](#) (was formerly 2010-A3)

[A3 Cross-Site Scripting \(XSS\)](#) (was formerly 2010-A2)

[A4 Insecure Direct Object References](#)

[A5 Security Misconfiguration](#) (was formerly 2010-A6)

[A6 Sensitive Data Exposure](#) (2010-A7 Insecure Cryptographic Storage and 2010-A9 Insufficient Transport Layer Protection were merged to form 2013-A6)

[A7 Missing Function Level Access Control](#) (renamed/broadened from 2010-A8 Failure to Restrict URL Access)

[A8 Cross-Site Request Forgery \(CSRF\)](#) (was formerly 2010-A5)

[A9 Using Components with Known Vulnerabilities](#) (new but was part of 2010-A6 – Security Misconfiguration)

[A10 Unvalidated Redirects and Forwards](#)

Today's Problems are about the same as Yesterday's

OWASP Top 10 Most Critical Errors - 2017

OWASP Top 10 - 2013	→	OWASP Top 10 - 2017
A1 – Injection	→	A1:2017-Injection
A2 – Broken Authentication and Session Management	→	A2:2017-Broken Authentication
A3 – Cross-Site Scripting (XSS)	↘	A3:2017-Sensitive Data Exposure
A4 – Insecure Direct Object References [Merged+A7]	U	A4:2017-XML External Entities (XXE) [NEW]
A5 – Security Misconfiguration	↘	A5:2017-Broken Access Control [Merged]
A6 – Sensitive Data Exposure	↗	A6:2017-Security Misconfiguration
A7 – Missing Function Level Access Contr [Merged+A4]	U	A7:2017-Cross-Site Scripting (XSS)
A8 – Cross-Site Request Forgery (CSRF)	⊗	A8:2017-Insecure Deserialization [NEW, Community]
A9 – Using Components with Known Vulnerabilities	→	A9:2017-Using Components with Known Vulnerabilities
A10 – Unvalidated Redirects and Forwards	⊗	A10:2017-Insufficient Logging&Monitoring [NEW,Comm.]

OWASP – What Changed from 2013-2017

- Change has accelerated over the last four years, and the OWASP Top 10 needed to change. We've completely refactored the OWASP Top 10, revamped the methodology, utilized a new data call process, worked with the community, re-ordered our risks, rewritten each risk from the ground up, and added references to frameworks and languages that are now commonly used.
- Over the last few years, the fundamental technology and architecture of applications has changed significantly:
 - Microservices written in node.js and Spring Boot are replacing traditional monolithic applications. Microservices come with their own security challenges including establishing trust between microservices, containers, secret management, etc. Old code never expected to be accessible from the Internet is now sitting behind an API or RESTful web service to be consumed by Single Page Applications (SPAs) and mobile applications. Architectural assumptions by the code, such as trusted callers, are no longer valid.
 - Single page applications, written in JavaScript frameworks such as Angular and React, allow the creation of highly modular feature-rich front ends. Client-side functionality that has traditionally been delivered server-side brings its own security challenges.
 - JavaScript is now the primary language of the web with node.js running server side and modern web frameworks such as Bootstrap, Electron, Angular, and React running on the client.

OWASP – What Changed from 2013-2017

- New issues, supported by data:
 - A4:2017-XML External Entities (XXE) is a new category primarily supported by source code analysis security testing tools (SAST) data sets.
- New issues, supported by the community: We asked the community to provide insight into two forward looking weakness categories. After over 500 peer submissions, and removing issues that were already supported by data (such as Sensitive Data Exposure and XXE), the two new issues are:
 - A8:2017-Insecure Deserialization, which permits remote code execution or sensitive object manipulation on affected platforms.
 - A10:2017-Insufficient Logging and Monitoring, the lack of which can prevent or significantly delay malicious activity and breach detection, incident response, and digital forensics.
- Merged or retired, but not forgotten:
 - A4-Insecure Direct Object References and A7-Missing Function Level Access Control merged into A5:2017-Broken Access Control.
 - A8-Cross-Site Request Forgery (CSRF), as many frameworks include CSRF defenses, it was found in only 5% of applications.
 - A10-Unvalidated Redirects and Forwards, while found in approximately 8% of applications, it was edged out overall by XXE.

In Class Exercise

- Arrange into groups of 3
- Objective is to build a “quick” vulnerability assessment profile on a product using the resources just discussed in class

VIP NOTE: divide and conquer within your group

- Goto <https://www.cvedetails.com/top-50-products.php?year=2017>
- For your assigned product
 - Get information to describe what it is (what it does, vendor name, number vulnerabilities, ...)
 - List its 2019 types of vulnerabilities
 - Look at the instances of the different vulnerability types
 - Filter the list to CVSS scores > than 9
 - Select a CVE with the highest CVSS score
 - Get CWE information
 - Get related CVE(s) information
 - Get Metasploit Modules related to the CVE
 - Get CAPEC info (hint: search using CWE description)
 - Find additional info (papers, news articles, research efforts, technical reports, ...)
- Provide reconnaissance report on assigned product to Class

Group 1 – Debian Linux

Group 2 – Linux Kernel

Group 3 – Android

Group 4 – Mac Os X

Group 5 – Ubuntu Linux

Group 6 – iPhone Os

Group 7 – Windows 10

Group 8 – Foxit Reader

Group 9 – Safari

Group 10 – JRE

Group 11 – Wireshark

Group 12 – Autotrace

Assignment for ALL Students: Familiarize yourself with these different taxonomies and their contents. Knowing the types of information available in these resources and how to quickly access that information will be quite useful.